

GOVERNANCE FOR AI AT ENTERPRISE SCALE

Every AI decision in your enterprise, governed, audited, and provable.

Generative AI now sits on the regulated path — EU AI Act, SOC 2, ISO 27001, HIPAA, NIST AI RMF. systemprompt.io is the unified control, execution and audit layer between your workforce and every model your enterprise calls. One self-hosted control plane enforces per-user, per-role policy on every prompt, routes the call through a provider-neutral gateway, and writes one trace-id-bound audit row per decision — **391/sec/node**, p99 **163ms**, ten nodes for 23,000+ developers on one audit spine.

MEASURED · THIS STACK

The numbers a board can verify.

391

GOVERNED DECISIONS / SEC / NODE

163ms

P99 GOVERNANCE LATENCY

32,925

DECISIONS ON THE AUDIT SPINE

23,460

DEVELOPER SEATS AT 10 NODES

01 Core capabilities

>

CONTROL

Policy at every prompt

Per-user, per-role allow-list resolved on every call against a versioned policy table. Revocation lands in one TTL window; SSO untouched.

Per-call access control

>

AUDIT

One spine for the fleet

Every prompt, tool call and cost row joined by trace_id in one append-only table. 32,925 decisions audited here; 22% denied at the gateway.

Regulator-grade trail

>

SCALE

Linear horizontal scale

Stateless API tier. 391 req/s/node, p99 163ms, 1,000/1,000 sustained. Add nodes; policy table and audit spine stay one.

391 req/s/node

>

SOVEREIGNTY

On infrastructure you own

Self-hosted in your VPC. Anthropic, Bedrock, Vertex, Azure, self-hosted Llama — routable per role, per region. Data never leaves your tenancy.

Self-hosted · provider-neutral

02 Why the world's largest enterprises pick systemprompt.io

→

Regulatory defensibility, not best-effort logging

The artefact the regulator asks for — who, what model, under which policy version, what outcome — is one SQL query, not a forensic dig across N container logs.

→

One control plane, every region you operate in

One policy table, one audit spine; every replica writes to it. Revocation is a row change — no rolling restart, no SSO propagation wait, no collateral access loss.

→

Scale-out proven on a demo you can run

391 req/s/node @ p99 163ms, 1,000/1,000 at 100 concurrent. 2,346 seats/node — 23,460 at ten. Reproducible from 02-load-test.sh.

COMPLIANCE	EU AI Act Art. 9/12/15 · SOC 2 CC6.1/CC7.2 · ISO 27001 A.5.15/A.8.25 · HIPAA §164.312 · NIST AI RMF · OWASP Agentic Top 10.
IDENTITY	JWT-bound role · PolicyResolver with 60s cache over ai_gateway_policies · SSO / OIDC upstream.
TOPOLOGY	LB → N stateless replicas + isolated scheduler · primary/replica Postgres · cross-replica events via LISTEN/NOTIFY.
DEPLOYMENT	Self-hosted in your VPC · Docker Compose · Kubernetes + HPA · BSL-1.1 · no telemetry to the vendor.
OBSERVABILITY	OpenTelemetry · x-served-by per response · Splunk · ELK · Datadog exporters.
THROUGHPUT	391 req/s/node governance · 1,495 req/s/node audit ingest · 1,000/1,000 at 100c · ~23,460 seats at 10 nodes.

PROVIDER-NEUTRAL · ROUTED PER ROLE, PER REGION

Direct: Anthropic · OpenAI · Gemini · Groq Cloud: Bedrock · Vertex AI · Azure Foundry

Self-hosted: Llama · Qwen · any /v1/messages Routing: per-call · per-role · per-region

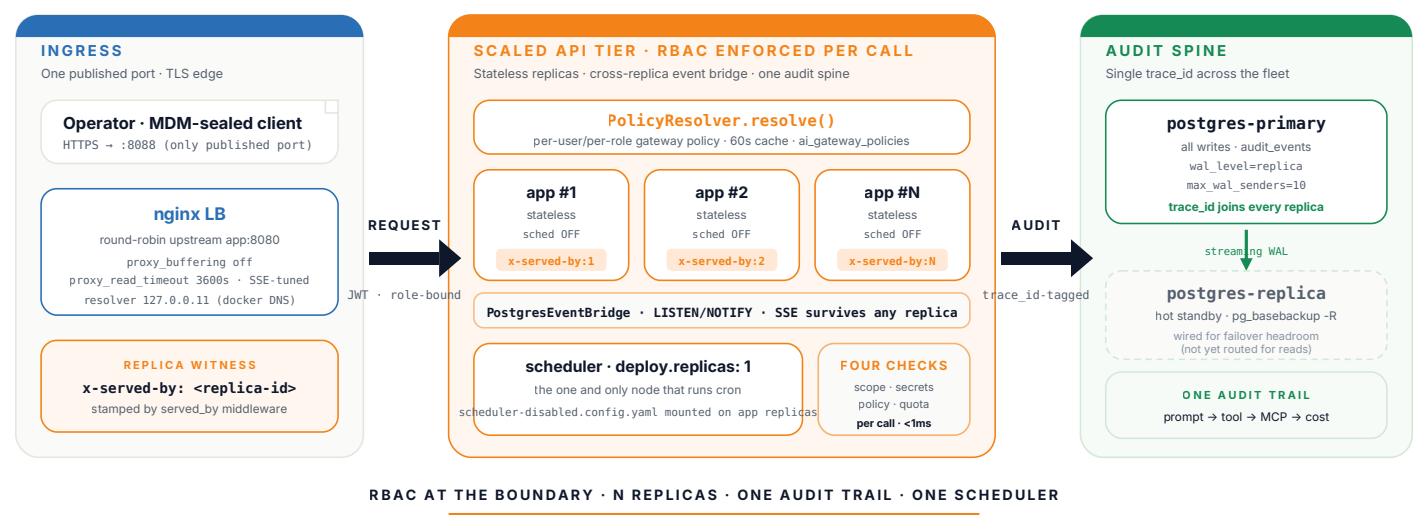
Every number on this page is reproducible. Run the scripts that wrote them.

BSL-1.1 · self-hosted · no telemetry leaves the host.

github.com/systempromptio/systemprompt-template

ed@systemprompt.io

03 One control plane. Many replicas. Every call governed.



GOVERNANCE AT THE BOUNDARY Every replica enforces the same versioned policy and writes back to the same audit spine. Add nodes for capacity; the policy table and the trace-id-bound audit log stay singular. The hot standby is wired for failover headroom (open item in the scenario's known-limits).

04 Where the unified control plane changes the answer

	Vendor-hosted AI (e.g. Claude Enterprise)	Single-instance DIY gateway	systemprompt.io control plane
ACCESS & IDENTITY			
Access control granularity	Per seat / SSO group	Per tenant	Per user, per role, per call — on every prompt
Revoke access to a model	Remove from SSO group — minutes to hours	Edit YAML and redeploy the fleet	One database row. SSO untouched. Effective within one cache TTL.
AUDIT & REGULATORY DEFENSIBILITY			
Regulator-ready audit	Vendor portal · vendor retention	Container logs per host	One append-only table, joined by trace_id, queryable in SQL — identity → policy version → model → outcome → cost
SCALE & SOVEREIGNTY			
Horizontal scale	Vendor-managed (opaque)	One process · vertical only	Linear add-a-node — 391 req/s/node measured; 23,460 seats at 10 nodes
Where the data lives	Vendor cloud, vendor region	Your host, but no governance layer	Your VPC, your region, your tenancy — provider-neutral routing

05 Built for the executives accountable for enterprise AI

FOR THE CHIEF RISK OFFICER

An audit trail that survives regulator review.

Every prompt, tool call and cost row on one trace-id-bound spine. The EU AI Act / SOC 2 / ISO 27001 evidence pack is a query, not a quarterly project.

Outcome: Compliance becomes a query, not a quarter.

FOR THE CISO

Zero-trust on every prompt.

Per-user, per-role, per-call enforcement against a versioned policy table. Revocation is a row change — no rolling restart, no SSO wait. 22% denied at the gateway here; every one logged.

Outcome: Access control that survives the audit.

FOR THE CIO / PLATFORM LEAD

One control plane, every region.

391 req/s/node, p99 163ms, 1,000/1,000 sustained. Add nodes for capacity; policy table and audit spine stay one. Provider-neutral routing — per role, per region.

Outcome: Capacity is a number; sovereignty is a posture.

Take the control plane for a board-ready test drive.

Self-hosted. BSL-1.1. No telemetry to the vendor.

Five runnable assertions ship with the demo: throughput & capacity, LB fairness, cross-replica events, scheduler isolation, audit-spine equality. Every number on this sheet is reproducible.

demo/scenarios/scaled/architecture.md